

Genossi

Revisionssicherheit des Audit-Logs

Technische Dokumentation für Prüfer und Betreiber

Version: 1.0

Stand: 16. April 2026

Herausgeber: Genossi-Projekt

Inhalt

1	Zweck und Geltungsbereich	1
1.1	Zugrunde gelegte Normen	1
2	Architekturüberblick	2
3	Audit-Log: Inhalte	3
3.1	Protokollierte Entitäten	3
3.2	Protokollierte Operationen	3
3.3	Felder eines Audit-Eintrags	3
4	Unveränderbarkeit durch Hash-Kette	5
4.1	Prinzip	5
4.2	Hash-Berechnung	5
4.3	Interne Verifikation	5
5	Qualifizierter elektronischer Zeitstempel	6
5.1	Zweck	6
5.2	Ablauf	6
5.3	Intervall	6
5.4	Auswahl der TSA	7
6	Rollen und Zugriff	8
7	Aufbewahrung und Export	9
7.1	Datenbank	9
7.2	Externe Spiegelung (optional)	9
8	Verifikation durch einen Prüfer	10
8.1	1. Interne Verifikation	10
8.2	2. Sichtprüfung der Zeitstempel-Einträge	10
8.3	3. Externe Verifikation des TSR-Tokens	10
9	Konfiguration durch den Betreiber	11
10	Grenzen der Implementierung	12
11	Anhang A – Begriffe	13
12	Anhang B – Referenzen	14

1 Zweck und Geltungsbereich

Dieses Dokument beschreibt die Mechanismen, mit denen die Software **Genossi** die Nachvollziehbarkeit und Unveränderbarkeit schreibender Änderungen an geschäftsrelevanten Daten sicherstellt. Es richtet sich an:

- **Prüfer** (insbesondere Genossenschaftsprüfer gemäß § 53 GenG), die sich einen Überblick über das Kontrollsystem verschaffen möchten, sowie
- **Betreiber** der Software, die den Nachweis gegenüber Dritten (Prüfungsverband, Aufsichtsrat, externe Revision) führen wollen.

Die Darstellung ist auf die für die Prüfung wesentlichen Aspekte beschränkt. Detaillierte Implementierungshinweise und Entwickler-Informationen finden sich in der Code-Dokumentation des Projekts.

1.1 Zugrunde gelegte Normen

Die nachfolgend beschriebenen Mechanismen sind am Maßstab der folgenden Regelwerke ausgerichtet:

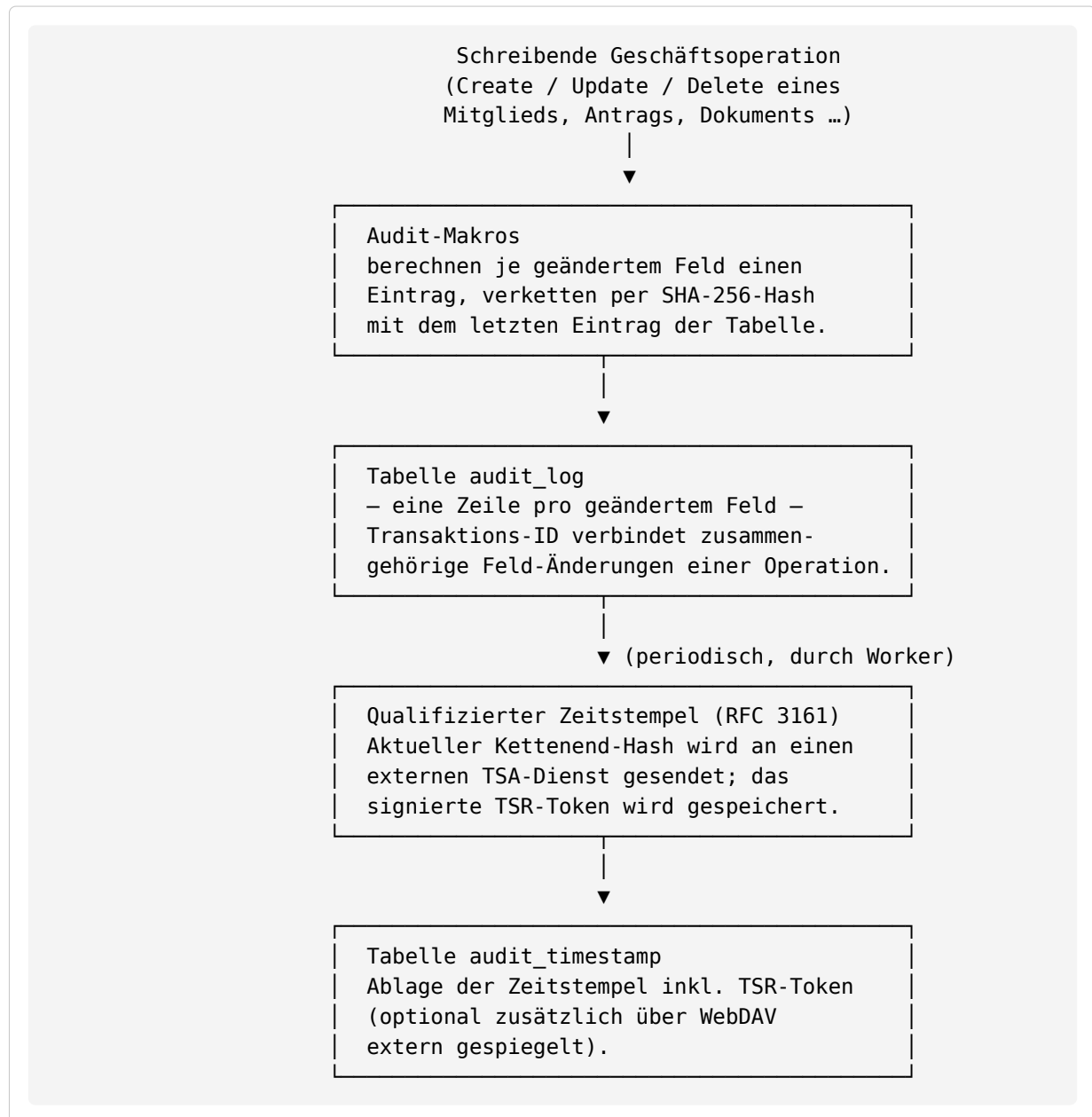
GoBD	Grundsätze zur ordnungsmäßigen Führung und Aufbewahrung von Büchern, Aufzeichnungen und Unterlagen in elektronischer Form sowie zum Datenzugriff (BMF-Schreiben)
§ 239 HGB	Anforderungen an die Führung von Handelsbüchern (u. a. Unveränderbarkeit, Nachvollziehbarkeit)
eIDAS-VO	Verordnung (EU) Nr. 910/2014, insbesondere Art. 41 und 42 (qualifizierte elektronische Zeitstempel)
RFC 3161	Internet X.509 Public Key Infrastructure Time-Stamp Protocol — technisches Protokoll für den Austausch mit Zeitstempeldiensten
§ 53 GenG	Prüfungspflicht eingetragener Genossenschaften

Kernaussage

Änderungen an geschützten Entitäten werden in einer kryptografisch verketteten Hash-Kette (SHA-256) protokolliert. In regelmäßigen Abständen wird das aktuelle Ende der Kette durch einen **qualifizierten elektronischen Zeitstempel** nach eIDAS an einen externen Vertrauensdienst gebunden. Damit lässt sich nachträgliche Veränderung oder Rückdatierung von Datensätzen nachweisbar ausschließen.

2 Architekturüberblick

Die Audit-Funktion ist in mehrere Schichten gegliedert und nutzt ausschließlich etablierte Standards (SHA-256, ISO 8601, RFC 3161):



Die Trennung zwischen **innerer Integrität** (Hash-Kette) und **externer Verankerung** (qualifizierter Zeitstempel) ist bewusst gewählt: Die Kette erkennt jede nachträgliche Manipulation innerhalb der Datenbank; der Zeitstempel verhindert, dass eine manipulierte Kette unbemerkt auf einen konsistenten Zustand zu einem früheren Zeitpunkt zurückgerechnet werden kann.

3 Audit-Log: Inhalte

3.1 Protokolierte Entitäten

Geschützte Geschäftsdaten werden bei jeder schreibenden Operation protokolliert. Aktuell sind folgende Entitätstypen erfasst:

- **Member** — Mitgliedsdatensätze der Genossenschaft
- **MemberAction** — an einem Mitglied durchgeführte Vorgänge
- **MemberDocument** — einem Mitglied zugeordnete Dokumente
- **Application** — Beitrittsanträge

Weitere Entitäten können durch Implementierung des internen `Auditable`-Merkmals und Verwendung der zugehörigen Audit-Makros ergänzt werden. Der Protokollierungsmechanismus ist für zukünftige Erweiterungen vorgesehen.

3.2 Protokolierte Operationen

Erfasst werden die folgenden Operationstypen:

<code>create</code>	Anlegen eines neuen Datensatzes
<code>update</code>	Änderung bestehender Feldwerte
<code>delete</code>	Löschung (als „weiches“ Löschen über ein Lösch-Datum)
<code>snapshot</code>	Vollständige Abbildung eines Datensatzes (administrative Nachdokumentation)

3.3 Felder eines Audit-Eintrags

Jede Zeile der Tabelle `audit_log` entspricht genau einem geänderten Feld eines Datensatzes und enthält:

<code>id</code>	Eindeutige Kennung des Audit-Eintrags (UUID)
<code>timestamp</code>	Zeitpunkt der Erfassung in UTC, ISO 8601
<code>user_id</code>	Anmelde-Identität des auslösenden Benutzers (bei Systemaktionen: <code>SYSTEM</code>)
<code>process</code>	Bezeichnung des auslösenden Prozesses (z. B. <code>member-service</code> , <code>audit-snapshot</code>)
<code>transaction_id</code>	UUID, die alle Feldänderungen einer Geschäftsoperation zusammenfasst
<code>entity_type</code>	Typ der betroffenen Entität (z. B. <code>member</code>)
<code>entity_id</code>	UUID der betroffenen Entität
<code>action</code>	<code>create</code> / <code>update</code> / <code>delete</code> / <code>snapshot</code>
<code>field_name</code>	Name des geänderten Feldes
<code>old_value</code>	Vorheriger Wert (bei <code>create</code> leer)
<code>new_value</code>	Neuer Wert (bei <code>delete</code> leer)
<code>prev_hash</code>	Hash-Wert des vorangehenden Audit-Eintrags
<code>entry_hash</code>	Hash-Wert dieses Eintrags (siehe Abschnitt 4)

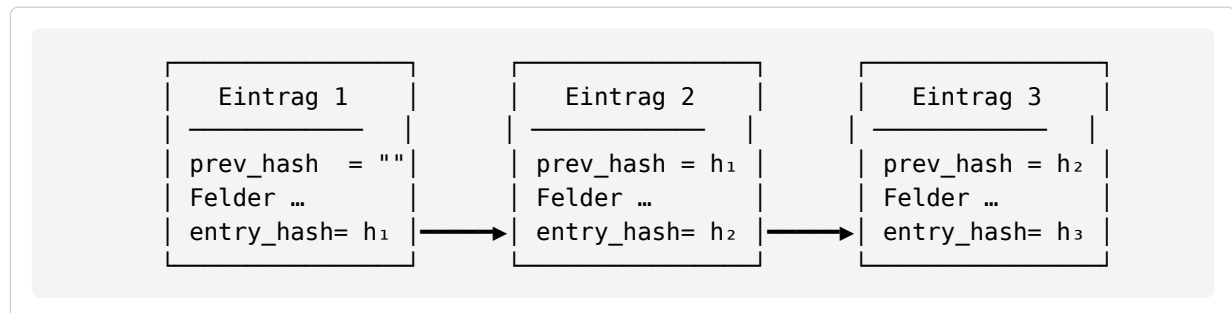
Granularität

Pro geändertem Feld wird eine **eigene** Zeile geschrieben. Eine Operation, die drei Felder eines Mitglieds ändert, erzeugt drei Zeilen mit derselben `transaction_id`. Das ermöglicht eine feldgenaue Rekonstruktion der Änderungshistorie.

4 Unveränderbarkeit durch Hash-Kette

4.1 Prinzip

Die Audit-Einträge bilden eine lineare Kette: Der `entry_hash` eines Eintrags geht in den `prev_hash` des **nächsten** Eintrags ein. Jede nachträgliche Änderung an einem bereits geschriebenen Eintrag zerstört die Konsistenz aller nachfolgenden Hashes und ist damit eindeutig erkennbar.



Eine Manipulation z. B. des `new_value` in Eintrag 2 ändert `h2`. Da `h2` aber in `prev_hash` von Eintrag 3 festgeschrieben ist, wäre auch Eintrag 3 neu zu berechnen – und alle folgenden. Ohne gleichzeitige Änderung **aller** späteren Einträge **und** der Zeitstempel-Einträge (siehe Abschnitt 5) wird jede Manipulation sofort erkannt.

4.2 Hash-Berechnung

Der `entry_hash` wird als SHA-256 über eine kanonische Repräsentation aller Eintragsfelder gebildet. Eingehende Bestandteile in fester Reihenfolge:

1. Zeitstempel (ISO 8601, UTC)
2. Benutzer-Identität (`user_id`)
3. Prozess-Bezeichnung
4. Transaktions-UUID
5. Entitätstyp
6. Entitäts-UUID
7. Operation (`action`)
8. Feldname
9. Alter Wert
10. Neuer Wert
11. Hash des vorangehenden Eintrags (`prev_hash`)

Die Verwendung von SHA-256 entspricht dem aktuellen Stand der Technik für kryptografische Hash-Funktionen und gilt nach Einschätzung des BSI als sicher.

4.3 Interne Verifikation

Die Software stellt eine Funktion `verify_chain` bereit, die für eine Menge von Audit-Einträgen prüft:

- ob jeder Eintrag den im Datensatz gespeicherten `entry_hash` trägt, der sich aus den obigen Feldern tatsächlich neu berechnen lässt, und
- ob die `prev_hash` -Werte eine lückenlose Kette bilden.

Die REST-Schnittstelle `GET /api/audit/verify` führt diese Prüfung über die gesamte Kette aus und meldet etwaige „broken links“ (fehlerhaft verkettete oder manipulierte Einträge).

5 Qualifizierter elektronischer Zeitstempel

5.1 Zweck

Die Hash-Kette allein beweist, dass keine **innere** Inkonsistenz vorliegt. Ein Angreifer mit vollständigem Datenbankzugriff könnte theoretisch die gesamte Kette inklusive aller Hashes neu berechnen. Um dies wirksam zu verhindern, wird der aktuelle Kettenend-Hash in regelmäßigen Abständen an einen **externen Vertrauensdiensteanbieter** gebunden.

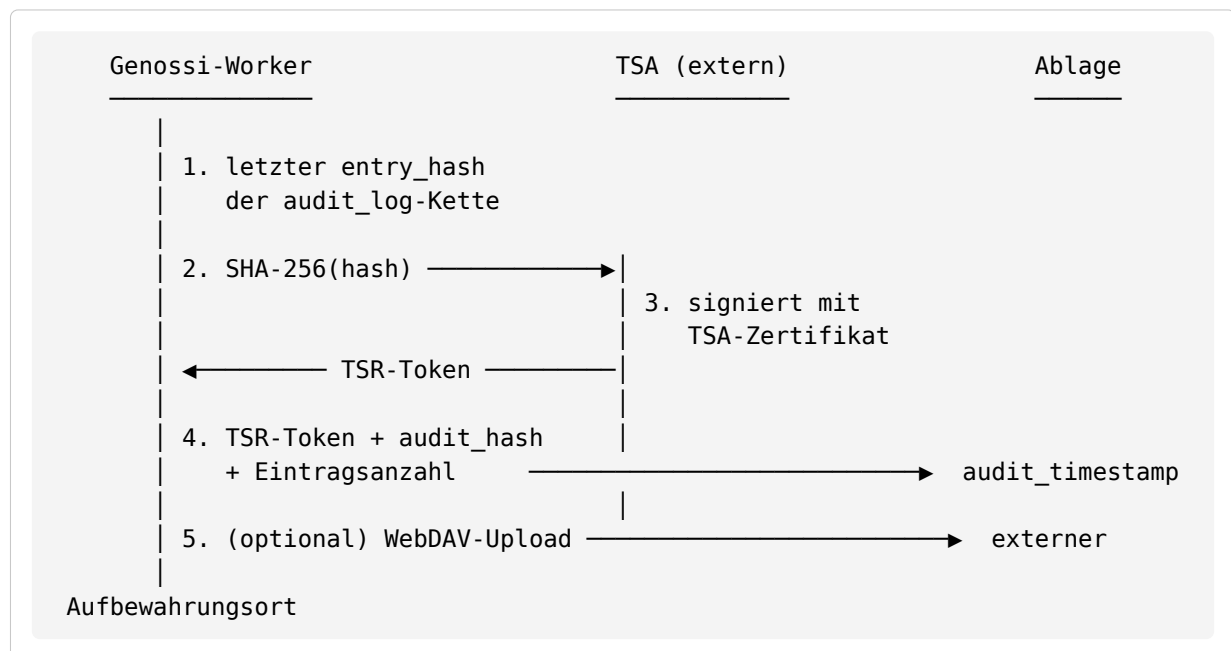
Hierfür nutzt die Software das **Time-Stamp Protocol** nach RFC 3161. Der externe Dienst (Time Stamping Authority, kurz TSA) signiert den eingereichten Hash zusammen mit seinem eigenen Zeitsignal. Das resultierende **TSR-Token** ist durch das Zertifikat des TSA rechtlich gesichert.

Wird eine TSA aus der **EU Trust List** (LOTL) verwendet, die als qualifizierter Vertrauensdiensteanbieter nach eIDAS gelistet ist, sind die erzeugten Zeitstempel **qualifizierte elektronische Zeitstempel** im Sinne von Art. 42 eIDAS-VO. Sie genießen damit die unionsrechtliche Beweisqualität einer vermuteten Richtigkeit von Zeit und Integrität der signierten Daten.

Rolle der TSA

Die TSA sieht **keine** vertraulichen Daten. Übertragen wird nur ein Hashwert. Rückschlüsse auf die zugrundeliegenden Audit-Einträge sind damit ausgeschlossen. Die Einbindung einer externen TSA verletzt damit keine Geheimhaltungspflichten.

5.2 Ablauf



Wichtig: **An keinem Punkt verlassen Klartextdaten das System.** Der TSA erhält lediglich einen Hashwert.

5.3 Intervall

Der Worker wird in einem durch den Betreiber konfigurierbaren Intervall ausgelöst. Standardwert ist eine Woche (168 Stunden). Hat sich der Kettenend-Hash seit dem letzten Zeitstempel nicht geändert (z. B. weil

keine Änderungen stattfanden), unterbleibt ein erneuter Aufruf des TSA, und es werden keine Kosten verursacht. Vgl. Abschnitt 9 zur Konfiguration.

5.4 Auswahl der TSA

Die konkrete Wahl der TSA erfolgt durch den Betreiber. Für die prüfungsrelevante Qualifikation als **qualifizierter Zeitstempel** ist ein Anbieter aus der EU Trust List erforderlich. Eine aktuelle Liste findet sich unter:

<https://eidas.ec.europa.eu/efda/tl-browser/>

Die konkret eingesetzte TSA einer Installation ist in der **Betreiber-Dokumentation** einzutragen (siehe separate Vorlage `template-betreiber.de.pdf`).

6 Rollen und Zugriff

Das Audit-System trennt zwischen Lese- und Schreibrechten:

Normale Benutzer	Lösen durch ihre Geschäftsvorgänge Audit-Einträge aus, können die Audit-Einträge selbst aber nicht einsehen, ändern oder löschen.
Administratoren	Können den vollständigen Audit-Log über die REST-Schnittstelle abrufen sowie die Integrität der Kette und der Zeitstempel prüfen. Sie können keine Einträge ändern oder löschen — die Datenstruktur sieht dafür keine Operation vor.
Technische Systemprozesse	Der Zeitstempel-Worker arbeitet unter der Identität <code>SYSTEM</code> und darf ausschließlich neue Zeitstempel-Einträge schreiben.

Keine API zum Löschen

Die Software stellt weder REST-Endpunkte noch Service-Methoden bereit, um einen Audit-Eintrag zu ändern oder zu entfernen. Nur ein administrativer Eingriff in die zugrundeliegende Datenbank könnte einen Eintrag manipulieren — ein solcher Eingriff bricht jedoch die Hash-Kette und ist damit anhand der internen und externen Verifikation nachweisbar.

7 Aufbewahrung und Export

7.1 Datenbank

Audit-Log-Einträge und Zeitstempel werden in derselben Datenbank wie die Geschäftsdaten abgelegt. Für die Datensicherung gelten damit dieselben Regeln wie für die übrigen Geschäftsdaten (Backup-Konzept des Betreibers).

7.2 Externe Spiegelung (optional)

Die Software bietet die Möglichkeit, TSR-Token nach erfolgreicher Erzeugung automatisch an einen externen Speicher (WebDAV) zu übertragen. Damit liegt mindestens ein vollständiger Zeitstempel-Beleg außerhalb des primären Systems. Dies entspricht dem Grundgedanken der GoBD, nach dem „Beweismittel außerhalb des Buchführungssystems“ zusätzlichen Schutz gegen Manipulation bieten.

Die Tabelle `audit_timestamp` hält für jede Zeitstempel-Transaktion neben den Basisdaten (Zeitpunkt, zugehöriger Hash, Anzahl der abgedeckten Einträge, Status) auch das rohe TSR-Token als binäres Datenfeld vor. Dieses Token kann zur externen Verifikation jederzeit exportiert werden.

8 Verifikation durch einen Prüfer

Ein Prüfer hat drei voneinander unabhängige Möglichkeiten, die Integrität der Audit-Kette zu überprüfen. Die Unabhängigkeit der Werkzeuge ist dabei ein bewusster Teil des Kontrollkonzepts.

8.1 1. Interne Verifikation

Über die Administrations-Oberfläche kann die Prüfung der Hash-Kette ausgelöst werden (Aufruf von `GET /api/audit/verify`). Das System gibt zurück, ob die Kette konsistent ist. Diese Prüfung ist jederzeit möglich und verursacht keine Kosten.

8.2 2. Sichtprüfung der Zeitstempel-Einträge

Jeder Eintrag der Tabelle `audit_timestamp` zeigt:

- den Zeitpunkt, zu dem der Zeitstempel angefordert wurde,
- den zu diesem Zeitpunkt aktuellen Kettenend-Hash,
- die Anzahl der bis dahin erfassten Audit-Einträge und
- den Status (`success` bei erfolgreichem TSA-Rücklauf).

Über die Admin-Oberfläche können diese Daten eingesehen und als Nachweis abgedruckt werden.

8.3 3. Externe Verifikation des TSR-Tokens

Für eine vom System unabhängige kryptografische Prüfung kann ein TSR-Token exportiert und mit einem externen Werkzeug verifiziert werden. Empfohlen wird die offizielle **DSS Demo Webanwendung der Europäischen Kommission**:

<https://ec.europa.eu/digital-building-blocks/DSS/webapp-demo/>

Die Webanwendung prüft das Token gegen die EU Trust List (LOTL), verifiziert die Signatur des TSA-Zertifikats und liefert ein formales Prüfprotokoll als PDF. Das Ergebnis kann einem Prüfbericht unmittelbar beigelegt werden.

Ablauf einer externen Verifikation

1. Ein aktueller Zeitstempel-Eintrag wird über die Admin-Oberfläche gewählt.
2. Das zugehörige TSR-Token wird als Datei exportiert.
3. Die Datei wird auf der DSS-Webanwendung hochgeladen.
4. Die Anwendung zeigt Signaturstatus, Zertifikatskette und Zeitangabe und bietet ein signiertes Prüfprotokoll zum Download an.

9 Konfiguration durch den Betreiber

Die Software trifft bewusst keine Annahme darüber, welcher Vertrauensdiensteanbieter verwendet wird. Der Betreiber konfiguriert:

<code>tsa_enabled</code>	Aktivierung der Zeitstempel-Funktion (<code>true</code> / <code>false</code>)
<code>tsa_url</code>	URL des TSA-Endpunkts (RFC 3161)
<code>tsa_user</code> (optional)	Benutzername bei HTTP Basic Auth
<code>tsa_pass</code> (optional)	Passwort bei HTTP Basic Auth
<code>tsa_interval_hours</code>	Intervall zwischen Zeitstempel-Anforderungen

Der konkrete Wert dieser Einstellungen für eine bestimmte Installation ist Bestandteil der **Betreiber-Dokumentation**. Eine Vorlage steht dafür zur Verfügung.

10 Grenzen der Implementierung

Zu den Grenzen der aktuellen Implementierung gehört, dass die softwareeigene `verify`-Funktion die kryptografische **Signatur** des TSR-Tokens nicht eigenständig gegen das TSA-Zertifikat prüft; sie verifiziert stattdessen die **Kettenkonsistenz** sowie die Parsebarkeit des Tokens (Statuswert der TSA-Antwort).

Die eigentliche qualifizierte kryptografische Verifikation erfolgt bewusst durch einen externen, unabhängigen Prüfpfad (siehe Abschnitt 8.3). Dies entspricht dem in der Informationssicherheit üblichen Prinzip der **Trennung von Prüf- und Produktionswerkzeugen**: Ein möglicherweise manipuliertes System darf nicht gleichzeitig Produzent **und** alleiniger Prüfer seiner eigenen Beweise sein.

Hinweis

Für Prüfer: Diese Grenze ist transparent dokumentiert und architektonisch beabsichtigt. Der Nachweis der qualifizierten Signatur und damit der Rechtswirkung nach Art. 42 eIDAS-VO erfolgt über die externe DSS-Webanwendung der EU-Kommission.

11 Anhang A – Begriffe

SHA-256	Standardisierte Hash-Funktion (FIPS 180-4). Erzeugt aus beliebigem Input einen 256-Bit-Fingerabdruck. Kollisionsresistent nach heutigem Stand der Technik.
RFC 3161	Internet-Standard für Zeitstempel-Dienste. Definiert Anforderungs-Format („TimeStampReq“) und Antwort-Format („TimeStampResp“ mit TSR-Token).
TSA	Time Stamping Authority – Vertrauensdiensteanbieter, der nach RFC 3161 Zeitstempel ausstellt.
TSR-Token	Time-Stamp Response Token. Von der TSA signiertes Datenpaket, das den eingereichten Hash, einen Zeitstempel und die Signatur der TSA enthält.
eIDAS-VO	EU-Verordnung Nr. 910/2014 über elektronische Identifizierung und Vertrauensdienste. Regelt u. a. qualifizierte elektronische Zeitstempel (Art. 41–42).
EU Trust List (LOTL)	Offizielle Liste der von den EU-Mitgliedstaaten notifizierten qualifizierten Vertrauensdiensteanbieter.
GoBD	Grundsätze zur ordnungsmäßigen Führung und Aufbewahrung von Büchern, Aufzeichnungen und Unterlagen in elektronischer Form. BMF-Schreiben, letzte Fassung vom 28. November 2019.
DSS	Digital Signature Service. Open-Source-Werkzeug der EU-Kommission zur Verifikation elektronischer Signaturen und Zeitstempel gegen die EU Trust List.
Hash-Kette	Datenstruktur, bei der jeder Eintrag einen Hash des vorherigen Eintrags enthält. Änderungen am Anfang der Kette machen alle nachfolgenden Hashes ungültig und sind dadurch erkennbar.
Transaktions-UUID	Eindeutige Kennung, die alle zu einer Geschäftsoperation gehörenden Audit-Einträge zusammenfasst, auch wenn jede Feldänderung als eigene Zeile gespeichert wird.

12 Anhang B — Referenzen

- BMF: **Grundsätze zur ordnungsmäßigen Führung und Aufbewahrung von Büchern, Aufzeichnungen und Unterlagen in elektronischer Form sowie zum Datenzugriff (GoBD)**, Stand 28. November 2019.
- Verordnung (EU) Nr. 910/2014 des Europäischen Parlaments und des Rates vom 23. Juli 2014 über elektronische Identifizierung und Vertrauensdienste für elektronische Transaktionen im Binnenmarkt (**eIDAS-Verordnung**).
- IETF: **RFC 3161 — Internet X.509 Public Key Infrastructure Time-Stamp Protocol (TSP)**, August 2001.
- NIST: **FIPS PUB 180-4 — Secure Hash Standard**, August 2015.
- Europäische Kommission: **DSS Demo Webanwendung**, <https://ec.europa.eu/digital-building-blocks/DSS/webapp-demo/>.
- Europäische Kommission: **EU Trust List Browser**, <https://eidas.ec.europa.eu/efda/tl-browser/>.
- Bundesgesetzblatt: **Genossenschaftsgesetz (GenG)**, insbesondere § 53 (Prüfungspflicht).